# Windows Threat Landscape

From Identification to Automated Analysis

Gianluigi Imbelli

# Who am I?

Gianluigi Imbelli aka Pizzamarinarasadd 🍕



MSc Cybersecurity at the University of Milan

# Objectives



Build a methodological framework, by studying the Windows architecture and its security mechanisms in order to find exploitation and evasion vectors , lastly correlate the capabilities of the payloads capabilities  to MaaS models and APT.



- Select and implement standardized tools for static and dynamic analysis of malicious binaries.
- Apply practical concepts to analyze a real malware sample.

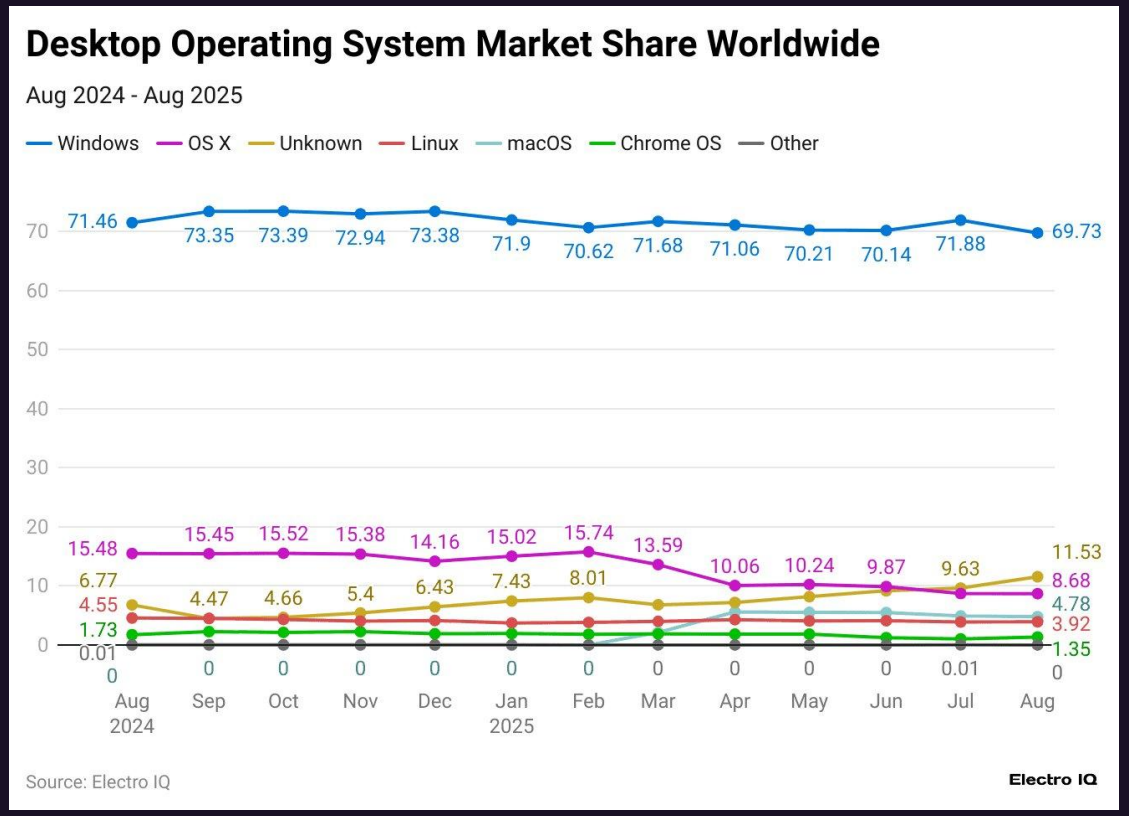


Assess the effectiveness of Agentic AI in order to speedup the Analysis.

# Why aiming Windows?

Windows remains the undisputed primary attack vector for large-scale threats. The rationale for malicious actors is purely statistical and economic.

- **Market Dominance:** Controls approximately 70% of the global desktop operating system market.
- **Scale of Operations:** Developing malware for Windows ensures the largest possible pool of potential victims.
- **Corporate Environments:** Widely adopted in enterprise networks, offering lucrative targets for ransomware and data extortion.



# Vulnerability Research recent drama

**Abdelhamid Naceri (Nightmare Eclipse):** Former Windows vulnerability researcher who parted ways with Microsoft under contentious circumstances, alleging wrongful termination and retaliatory blacklisting while nearing permanent EU residency. In response to the dispute and an ongoing legal battle, he publicly dropped a series of unpatched Windows zero-day privilege escalation exploits, including BlueHammer, RedSun, UnDefend, YellowKey, GreenPlasma, MiniPlasma, RoguePlanet, ShieldBreak, GreatXML, FalconFlank, LegacyHive, and ShieldCrash.

**Vasily Kravets (KillaBoi):** Independent security researcher and bug bounty hunter who identified a high-severity Local Privilege Escalation (LPE) vulnerability in the Windows Steam Client service. After Valve and HackerOne repeatedly dismissed his findings as out-of-scope and temporarily banned his account, he bypassed coordinated disclosure protocols and released a functional zero-day exploit publicly to compel remediation.



# Cybercrime cost

## Economic Impact

- The annual cost of cybercrime is expected to soar to a staggering $13.82 trillion by 2028.
- This massive economic scale actively fuels the industrialization of malware development, turning isolated attacks into highly organized criminal enterprises.

## Attack Anatomy (example)

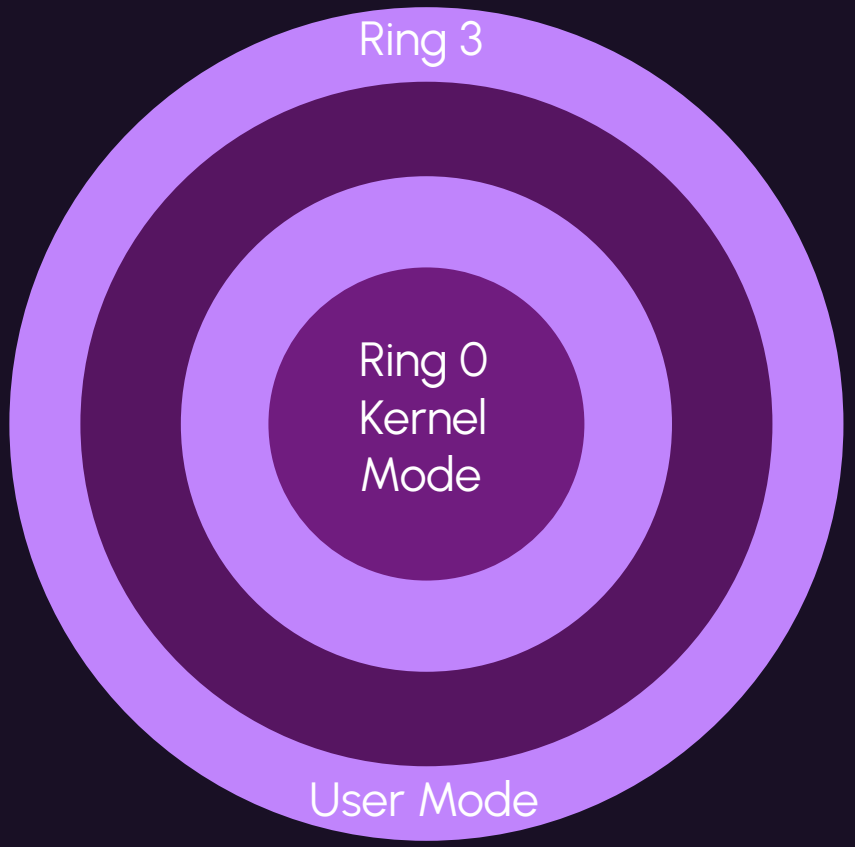
A typical ransomware sequence operates with ruthless efficiency:

1. Infiltration: Initial login via phishing.
2. Execution: The malware is decompressed locally.
3. C2 connection: Download public keys.
4. Extortion: Encrypted files, ransom note.

# Windows Architecture

Understanding privilege separation is fundamental to malware analysis. Modern processors use specific rings to dictate execution authority.

- **Ring 3 (User Mode):** Operates with limited privileges. Standard user applications and Win32 APIs reside here.
- **Switching Point:** The boundary where API calls translate into system calls.
- **Ring 0 (Kernel Mode):** Possesses full privileges to interact directly with hardware and physical memory.



# Analysis Methodologies



## Static Analysis

Analysis of the sample without executing it. We examine the binary structure, strings, and code layout to passively understand potential behaviors.



## Dynamic Analysis

Execution of the sample within a secure, isolated environment (sandbox) to observe its actual interactions with the system, network, and memory.



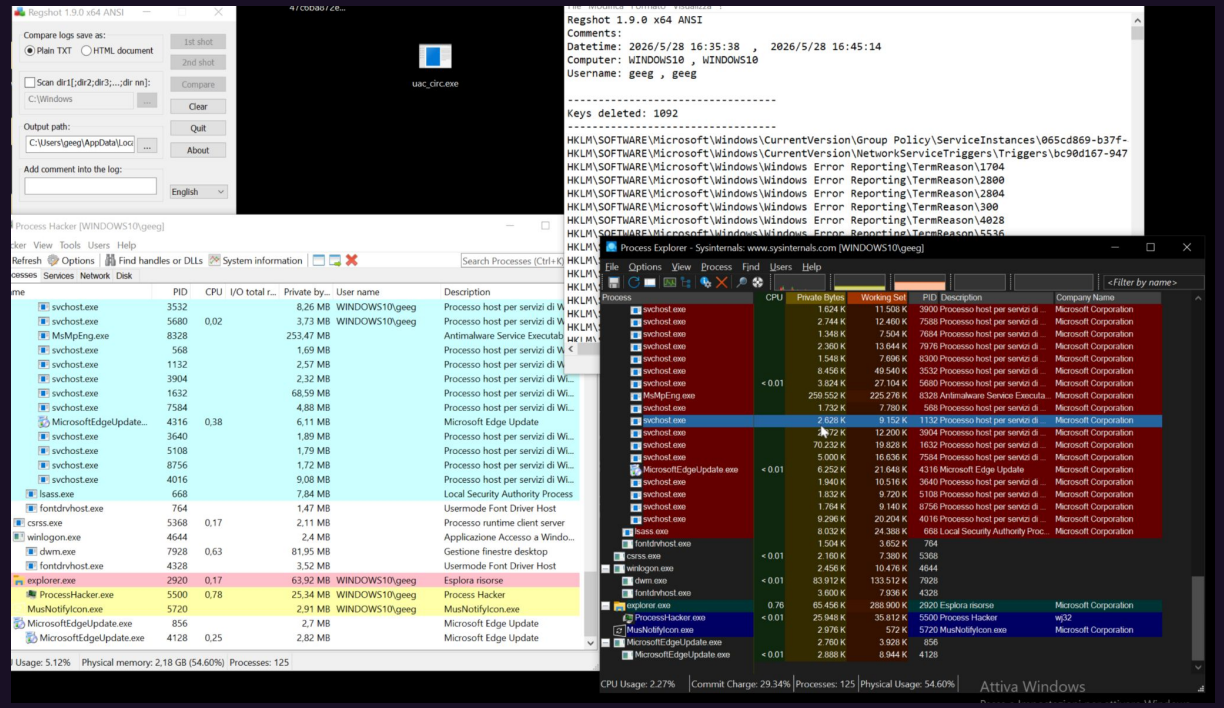
## Agentic Analysis

Sample execution using an automated framework, scaling our capacity to efficiently analyze complex threats.

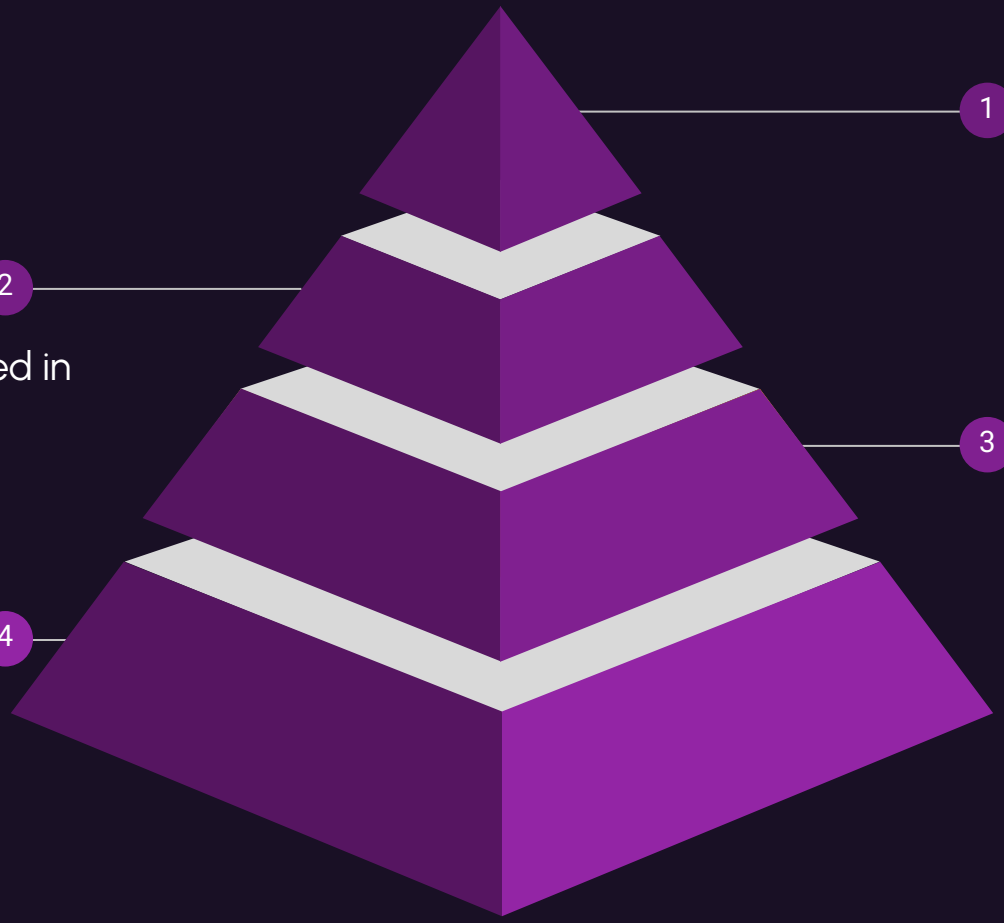
# Dynamic and Static Analysis Tools

Before automation, a manual baseline is established to isolate the actual malicious payload from standard wrappers.

- **Detect It Easy (DIE):** Used to identify the sample's architecture (e.g., 32-bit x86 PE32 executable) and detect packers or self-extracting archives.
- **Static Toolkit:** Includes Binary Ninja, dnSpy, and FLOSS for initial code and string de-obfuscation (e.g., identifying VB6 P-Code).
- **Dynamic Toolkit:** Leverage x64dbg for live debugging; Regshot, Wireshark, and ApateDNS for network traffic; and Procmon/Process Hacker for system behavior.



# Static Analysis Results



1 **SFX WinRAR**

Packer detected and confirmed with Resource Hacker.

2 **Crypter VB6**

Loader detected in Binary Ninja designed to confuse decompilers.

3 **Injector VB.NET**

Extracted as a compressed bundle containing LB3.exe, tttt.exe, build.exe, and a decoy PDF.

4 **Payload LockBit 3.0**

No function identified due to IAT hiding methods.

# Dynamic Analysis Results

## 1 Persistence and Anti-Forensics

Dropping of executables + Run key, custom file extension, event log deletion, ransom note.

## 2 Recovery Sabotage

It disables EventLog, Defender ATP, VSS before encryption and finally installs a malicious kernel service,

## 3 Active Evasion

Termination of analysis tools (e.g., Wireshark), anti-debugging via intentional exceptions, and environment validation (isTNT) prior to encryption.

## 4 Limitation

IAT hiding, JIT string deobfuscation, thread hiding, and 32-character guardrails that prevent manual IOC extraction.

# Agentic Analysis Flow

## 1. Extraction & Decompilation

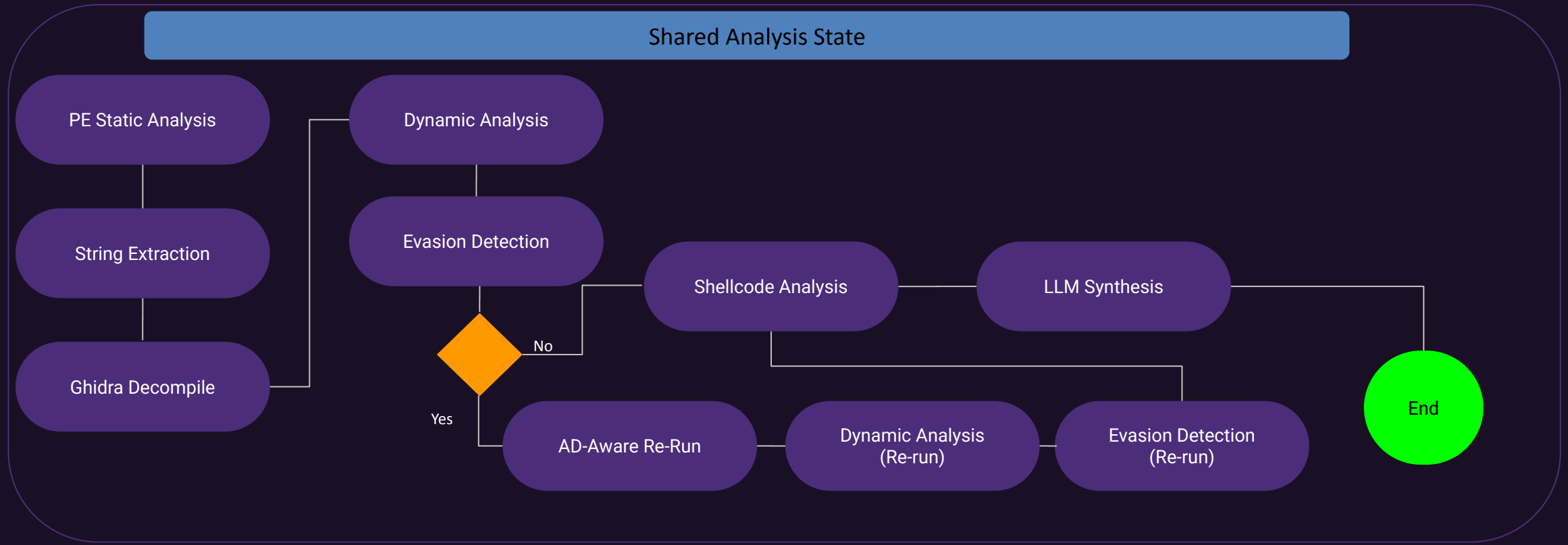
PER Static Analysis, String Extraction (FLOSS), and Ghidra Decompilation prepare the binary data.

## 2. Evasion Detection (CAPEv2)

Dynamic Analysis detects evasions (e.g., Domain-Join), triggering automated re-executions in AD-Aware mode.

## 3. LLM Synthesis (DeepSeek-R1:7B)

System interactions and the analyzed payload are passed to an LLM to generate a report.



# Agentic Analysis Results

```
Report saved to: /opt/cape-agent/reports/LB3un_20260620_133019.json
geeg@geeg-Standard-PC-Q35-ICH9-2009:/opt/cape-agent/reports$ /opt/cape-agent/analyze.sh
[*] Submitting: /opt/cape-agent/uploads/LB3un.exe
[*] This takes ~15-20 minutes. Please wait...

=== EVASION ===
SANDBOX EVASION LIKELY: malscore=0.0, heuristic=9.5/10 yet outbound :443 TCP observed. Sample may be dormant pending
an environmental trigger.
DOMAIN-JOIN EVASION: Sample loaded AD-related libraries (LOGONCLI.DLL, NETUTILS.DLL, SAMCLI.DLL, SRVCLI.DLL, WKSCLI.D
LL) and called domain-recon APIs (none). NetGetJoinInformation / DsGetDcName gate — dormant on workgroup VMs. AD-awar
e snapshot applied for this run.
IN-MEMORY UNPACKING / API UNHOOKING: NtProtectVirtualMemory called 20x — runtime DLL unhooking (toggles READWRITE↔EXE
CUTE on ntdll/security DLL pages) and/or shellcode injection.
ANTI-DEBUG: IsDebuggerPresent or equivalent called — sample checks for attached debugger.
PROCESS MASQUERADE: Renamed 'LB3un.exe' → 'dllhost.exe' to blend in with Windows infrastructure.
WMI ACCESS: IWbemLocator instantiated — WMI used for system enumeration, lateral movement, or persistence.
UAC BYPASS (CMLuaUtil): COM Elevation Moniker 'Elevation:Administrator!new:{3E5FC7F9-9A51-4367-9063-A120244FBEC7}' us
ed — auto-elevated COM object, no UAC prompt shown to user.
NTLM_CRYPTO [LB3un.exe]: Resolved MD4Final, MD4Init, MD4Update, MD5Final, MD5Init, MD5Update, SystemFunction040, Syst
emFunction041 — NTLM hash stack for credential harvesting (MD4=NT hash, MD5=NTLMv2 response)

=== VERDICT ===
## Threat Report

### 1. Overview
The sample appears to be attempting sandbox evasion by renaming a process and using domain join techniques. It also s
hows signs of API unhooking and potential credential harvesting.

### 2. Static Analysis Findings
- DOMAIN-JOIN EVASION
- IN-MEMORY UNPACKING / API UNHOOKING

### 3. Dynamic Analysis Findings
- WMI_ACCESS

### 4. Evasion & Behavioral Analysis
Evasion likely due to multiple indicators including domain join evasion, process renaming, and API unhooking.

### 5. MITRE ATT&CK TTPs
| Technique | ID | Evidence |
|-----------|-----|-----------|
| Virtualization/Sandbox Evasion: System Checks | T1497.001 | DOMAIN-JOIN EVASION: Sample loaded AD-related libraries
 (LOGONCLI.DLL, NETU… |
| Virtualization/Sandbox Evasion | T1497 | SANDBOX EVASION LIKELY: malscore=0.0, heuristic=9.5/10 yet outbound :443 T
C… |
| Process Injection | T1055 | IN-MEMORY UNPACKING / API UNHOOKING: NtProtectVirtualMemory called 20x — ru… |
| Impair Defenses: Disable or Modify Tools | T1562.001 | IN-MEMORY UNPACKING / API UNHOOKING: NtProtectVirtualMemory
called 20x — ru… |
| Debugger Evasion | T1622 | ANTI-DEBUG: IsDebuggerPresent or equivalent called — sample checks for atta… |
| Masquerading: Match Legitimate Name or Location | T1036.005 | PROCESS MASQUERADE: Renamed 'LB3un.exe' → 'dllhost.ex
e' to blend in with Wi… |
| Abuse Elevation Control Mechanism: Bypass UAC | T1548.002 | UAC BYPASS (CMLuaUtil): COM Elevation Moniker 'Elevatio
n:Administrator!new:… |
| Windows Management Instrumentation | T1047 | WMI ACCESS: IWbemLocator instantiated — WMI used for system enumeratio
n, la… |
| OS Credential Dumping | T1003 | NTLM_CRYPTO [LB3un.exe]: Resolved MD4Final, MD4Init, MD4Update, MD5Final, M… |

### 6. IOCs
**ips**: 20.231.128.67, 23.222.236.165, 20.231.128.67:443, 23.222.236.165:443

### 7. Analyst Verdict
MALICIOUS — confirmed evasion: ANTI-DEBUG, SANDBOX EVASION LIKELY, PROCESS MASQUERADE, IN-MEMORY UNPACKING, UAC BYPAS
S, DOMAIN-JOIN EVASION, NTLM_CRYPTO, WMI ACCESS

Report saved to: /opt/cape-agent/reports/LB3un_20260620_135043.json
```

- As can be seen, the first run,without evasion detection, yielded a malware score of 0, whereas with evasion detection, the score was 9.5.

- We must bear in mind that, given the use of a local AI with limited parameters, hallucinations can occur (e.g., identifying IOC IP addresses as Windows telemetry).

# Sandbox Hardening Results

| Parametro Modificato | VM Hardened (Host/Guest) | Stock QEMU/KVM |
|---|---|---|
| **BIOS/Firmware** | Dell OptiPlex 7090 | Stringhe native QEMU |
| **Scheda Video** | Intel UHD Graphics 630 | GPU virtuale generica |
| **CPUID Vendor** | AuthenticAMD | Microsoft Hv/KVM |
| **Topologia CPU** | 1 socket x 6 core logici | Default (2 core) |
| **Punteggio Pafish** | 95.45% check superati | 63.63% check superati |

*Note: The RDTSC (Read Time-Stamp Counter) check remains impossible to bypass at the software level in both configurations.

# Conclusions



Manual analysis is hindered by dynamic API hashing, JIT string decryption, and "-pass" guardrails. The agentic pipeline bypasses the evasion detection layer by correctly reclassifying the sample as malicious.



Manual analysis offers the depth needed to design resilient detection heuristics; agentic analysis offers the speed and scale required by the volume of modern cybercrime.



The "-pass" guardrail remains unbreached due to the absence of upstream artifacts; the 7B model exhibits occasional variability in ATT&CK mapping; the validation is a qualitative PoC based on a single variant, not yet a large-scale statistical study.

# Future Perspectives



## Automatic Unpacking

Implement pre-processing that dynamically classifies and unpacks loaders, ensuring the pipeline operates only on the actual malicious payload.



## SIEM integration

Transform the CLI tool into a FastAPI microservice to stream per-node verdicts directly into enterprise incident response workflows.



## Elf and multifamily

Extend the analysis to the ELF format and introduce a classification node that routes banking Trojans, info-stealers, and worms to dedicated analysis branches.

# Thanks!

For the attention paid during this presentation.